

SecCore Essentials - Client Hardening

 seccore.at/blog/client-security

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This blog post summarizes various client workstation related security hardening procedures. This SecCore Essential is considered implemented if the following conditions are met:

- Devices have Full Disk Encryption (FDE) implemented with for example the following software:
 - Microsoft Windows: **BitLocker**¹
 - GNU/Linux: **LUKS Encryption**²
 - macOS: **FileVault**³
- Users are not granted local administrator privileges by default
- Security updates are installed automatically on a regular basis
- A screen-lock timeout of at most 15 minutes is enforced
- All workstations have an active antivirus solution

Additionally, the following measures should be implemented for Microsoft Windows systems:

- Protections against credential stealing
 - **LSA Protection**⁴
 - **Credential Guard**⁵ (Windows Enterprise only!)

- **Virtualization-Based Security**⁶

- PowerShell Version 2 needs to be disabled

This can be done via PowerShell: `Disable-WindowsOptionalFeature -Online -FeatureName MicrosoftWindowsPowershellV2 -Remove`

- Disable the execution of Microsoft Office Macros

Introduction

Client workstations tend to be one of the most important endpoints in many enterprise environments. Employees use them for daily work like receiving E-Mails, creating and opening documents and interacting with internal and external applications. Therefore, it is important to implement a sensible set of security controls for them.

Common Attack Vectors

The following sections describe common attack vectors on client systems.

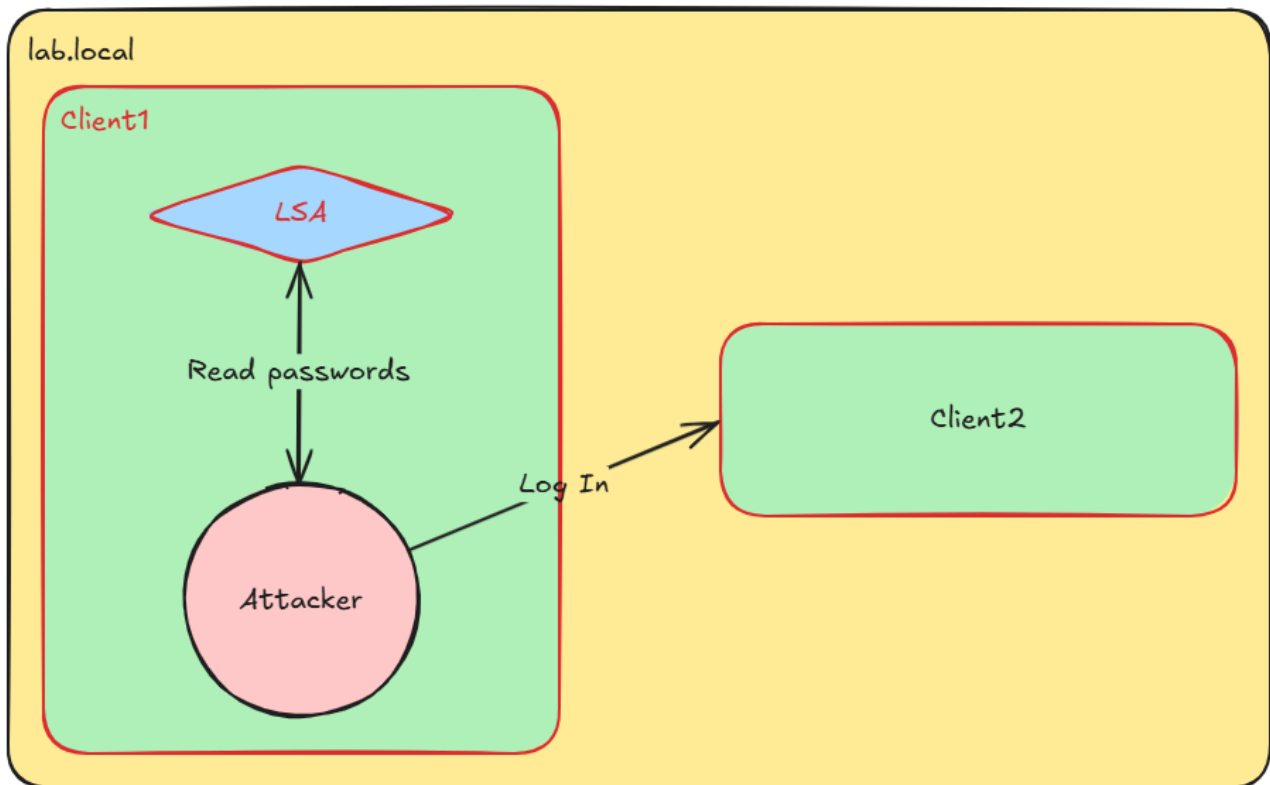
Phishing & Malware

Most breaches start with credential phishing or malware attacks on employees. An up-to-date antivirus (AV) solution, ideally combined with Endpoint Detection and Response (EDR) helps mitigate the risk of a successful malware infection.

Microsoft Office macro documents are still widely used by malicious actors for initial infections. There is a high chance that such documents will be opened, especially in departments with high external document traffic, such as human resources, purchasing, and logistics. Disabling macros generally reduces the risk of a successful infection via this vector.

Credential Theft & Lateral Movement

Attackers can easily dump credentials from memory or disk if protections are not enabled. These credentials can then be used to connect to other, possibly more sensitive systems.



Even though AV and EDR solutions may help mitigating and detecting such attacks, it is usually a better idea to proactively harden the credential storage on Microsoft Windows systems by enabling **LSA Protection**⁴ or **Credential Guard**⁵.

Unpatched Vulnerabilities

Since client systems are usually used for Internet browsing, opening emails and running software, it is important to keep them up to date. Regular updates should be applied not only to the base operating systems, but also to the installed software packages. Outdated browsers and email clients pose a significant risk of malware infection since they are often used to open unknown websites and emails.

A good patch management solution should also report systems with outdated and potentially vulnerable software, so that measures can be taken to update them manually if the need arises.

Physical Access

Mobile devices, such as laptops, are often targeted by thieves. This is because business devices are expensive and contain sensitive information that attackers can retrieve if the computer is not encrypted or locked.

One of the most important protection against real-life data theft is Full Disk Encryption. All modern operating systems provide an easy way to implement this security control with

BitLocker¹ for Microsoft Windows, **FileVault**³ for Apple macOS and **LUKS**² for GNU/Linux based systems.

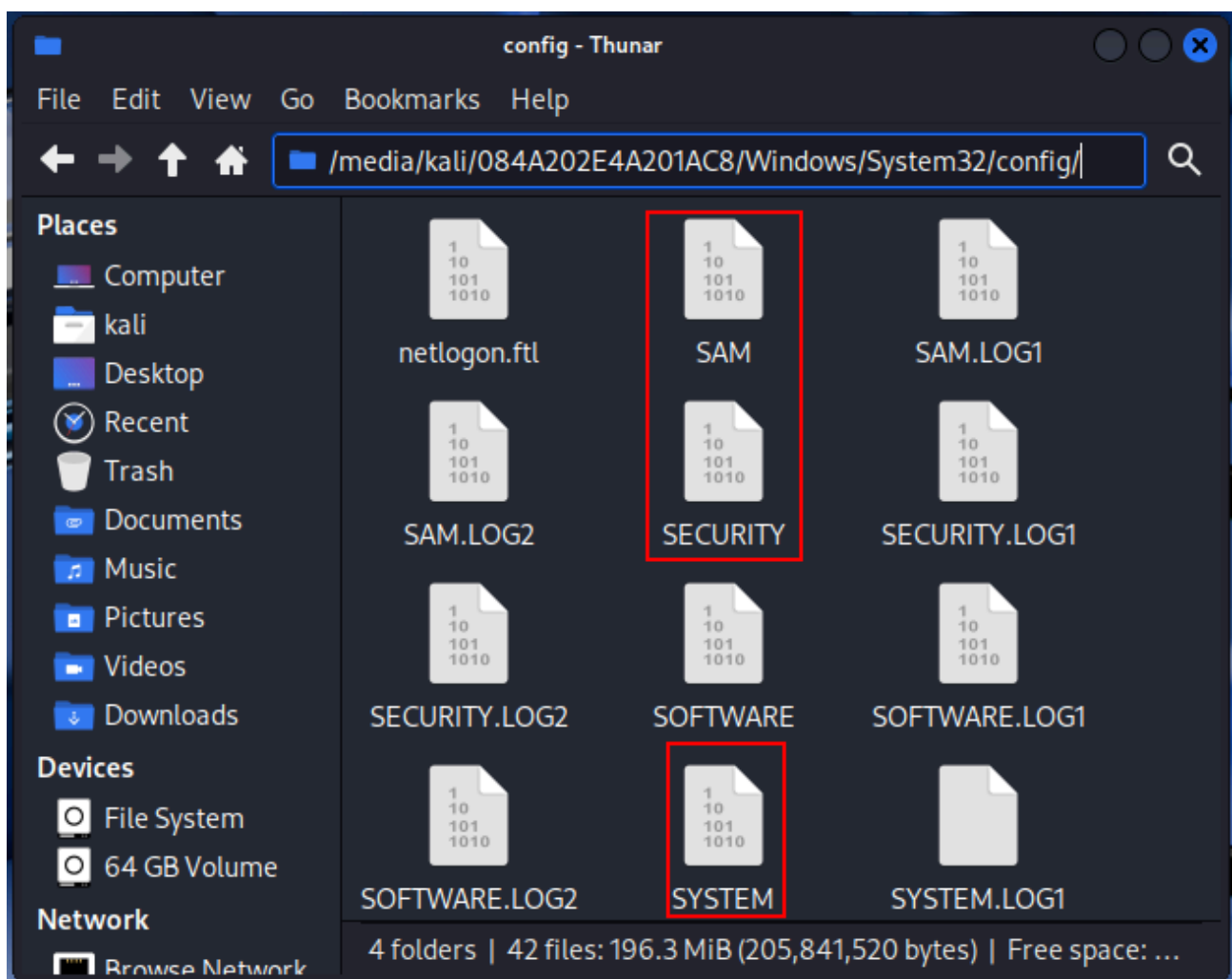
However, FDE is ineffective if a device is left unsupervised and unlocked, as an attacker could simply steal the device in this state or install malware directly. Therefore, it is recommended that an automatic lock timer is implemented for all devices.

Attack Scenario

This section should demonstrate how attackers may exploit physical access to a system. The setup of this attack scenario is as follows:

- The attacker got access to a client laptop without credentials
- FDE e.g. BitLocker is not enabled
- The attacker has no considerations regarding OPSEC, the most straight forward way is used

Since the attacker has no valid credentials to the stolen client laptop, they will attempt to access the system through physical means, such as removing the hard drive and connecting it to another machine. This reveals that the data on the hard drive is unencrypted and easily accessible:



By copying the highlighted files from the hard drive, the attacker can restore the password hashes of local user accounts, change those passwords to login with an administrative user or check if Local Security Authority (LSA) secrets are present on this system through **mimikatz**⁷ using the following command:

```
mimikatz# lsadump::secrets /system:c:\temp\system /security:c:\temp\security
```

This reveals the cleartext password of the user t2bob@lab.local:

```
Secret : NL$KM
cur/hex : b8 ce 04 c3 3e 89 e5 e9 ec 20 71 42 19 cf 26 b8 90 36 a9 0d 08 e9
12 43 ed b0 18 5f 66 c8 25 8e ab fc 00 f8 17 a6 d3 ae d6 4e 99 79 aa 42 0e
old/hex : b8 ce 04 c3 3e 89 e5 e9 ec 20 71 42 19 cf 26 b8 90 36 a9 0d 08 e9
12 43 ed b0 18 5f 66 c8 25 8e ab fc 00 f8 17 a6 d3 ae d6 4e 99 79 aa 42 0e

Secret : _SC_TestService / service 'TestService' with username : lab\t2bob
cur/text: ██████████
```

The LSA can store different kind of credentials, such as Internet Explorer saved passwords, RDP credentials or, like in this case, service user passwords. With these credentials, an attacker is able to log in to the system and enumerate the Active Directory domain.

Mitigation

By enabling FDE, even if a client gets stolen, an attacker is not able to easily access the data on the hard drive, as it will be encrypted and require authentication to unlock:

